IS05 — Backup Policy

[Company] IIoT Platform

Project name: [Company] Security Policies	Status: Active
Date: [Date]	Version: 1.0
Author: [Author Name]	Reviewer: [Reviewer Name]

Versions

Revision	Date	Author	Description
1.0	[Date]	[Author Name]	Initial release

Related Standards, Policies and Processes

- IS01 - [Company] Information Security Policy
- DP01 - Data Protection and Retention Policy

Definitions and Terms

Definitions and terms used in this policy follow the SANS Institute Glossary of Security Terms.

Overview

This policy outlines the requirements for backing up data within the [Company] IIoT Platform. Robust backup procedures are the primary defense against data loss caused by hardware failure, cyberattacks (such as ransomware), accidental deletion, or natural disasters.

Purpose

The purpose of this policy is to:

Ensure Business Continuity: Guarantee that critical business operations can be restored within acceptable timeframes (RTO) and with acceptable data loss (RPO) following a disruption.

Protect Data Integrity: Maintain immutable copies of data to recover from corruption or unauthorized changes.

Comply with Regulations: Meet legal, contractual, and audit requirements regarding data availability and retention.

Scope

All employees, contractors, consultants, temporary and other workers of [Company] working on the [Company] IIoT Platform must adhere to this policy. This policy applies to all operations and data maintained, processed and run on the [Company] platform and its components.

Policy

Backup Frequency and Schedule

Backup schedules must align with the criticality of the data and the Data Protection and Retention Policy (DP01). At a minimum:

Critical Data (e.g., Databases): must be backed up daily (retained 14 days), weekly (retained 4 weeks) and monthly (retained 12 months).

Configuration & State: Infrastructure-as-Code states and system configurations must be versioned and backed up upon every change.

Storage and Location

To ensure resilience against site-specific failures:

Geo-Redundancy: Backups must be stored in a geographically separate location from the primary production data.

Storage Flexibility: Backups may be stored on-premises or with third-party cloud vendors, provided that all relevant security regulations and compliance standards are strictly followed.

Immutability: Where supported, backup storage should utilize object locking (WORM - Write Once Read Many) to prevent modification or deletion by ransomware.

Encryption and Security

Encryption: All backups must be encrypted at rest. Encryption should be performed using [Company]-managed keys (Customer Managed Keys) wherever technically possible. Vendor-managed keys are permissible only when [Company]-managed keys are not feasible.

Access Control: Access to backup repositories containing Confidential or Restricted data must be strictly monitored. Access reviews must be performed regularly to ensure only authorized personnel have restoration capabilities.

Restoration Testing and Training

Regular Drills: Backups are only as good as the ability to restore them. Teams must perform regular recovery exercises and drills to verify backup integrity.

Training: Proper training must be provided to DevOps and operational teams to ensure they are proficient in executing restoration procedures under pressure.

Policy Compliance

Compliance Measurement

The Security Team will verify compliance through:

Automated Reporting: Monitoring of backup job success/failure rates.

Drill Reports: Reviewing documentation from mandatory restoration exercises.

Configuration Audits: Verifying encryption settings and key management practices.

Exceptions

Any exception to the policy must be justified by the owner and approved by the Security Team in advance.

Non-Compliance

An employee found to have violated this policy may be subject to disciplinary action.